Enterprise SSO

their login, their joiners, their leavers

Watch the 4-min video

In one line: for each enterprise tenant, trust **its own identity provider** via SAML or OpenID Connect, find it by email domain (**home realm discovery**), provision and deprovision users with **SCIM**, and map directory groups to app roles per tenant.

1 Three requests from every enterprise

A company with 20,000 employees buys your product. Its IT team asks: (1) our people sign in with **our corporate login**, with our password and MFA rules; (2) **new hires get access automatically**; (3) when someone leaves, their **access disappears the same day**. Every enterprise customer asks for these three; they are usually a precondition of the deal and a line in their security review.

2 Single sign-on, per tenant

Each customer has its own identity provider (IdP): Okta, Microsoft Entra ID, Google Workspace, Ping, ADFS. Your app is the **service provider** (SP, or relying party) and trusts each customer's IdP **separately**. Two protocols cover nearly everyone:

	SAML 2.0	OpenID Connect
Age / base	2005, XML	2014, on top of OAuth 2.0, JSON / JWT
What you receive	signed XML assertion, POSTed by the browser to your ACS URL	ID token (signed JWT) via the authorization code flow
Per-tenant config	IdP entity ID, SSO URL, signing certificate; your entity ID + ACS URL	issuer / discovery URL, client ID + secret, redirect URI
Where it dominates	enterprise IT, older IdPs	modern IdPs, mobile and SPA apps

Validate strictly. For SAML: the XML signature with the tenant's certificate (beware XML signature-wrapping attacks; use a maintained library), `Audience` equal to your entity ID, `Destination` / `Recipient`, the `NotOnOrAfter` time window, and `InResponseTo` matching the request you sent (IdP-initiated logins have no request to match, so they are easier to replay; many apps disable them or treat them carefully). Support **two certificates** per tenant during rotation, or SSO breaks for a whole company on rotation day.

3 Home realm discovery

With hundreds of IdPs, the login page must know which one to use. The user types an email; the domain `acme.com` maps to tenant `acme` and its SSO configuration; the user is redirected to Acme's Okta. Alternatives: a tenant subdomain (`acme.app.com`) or a tenant-specific login URL.

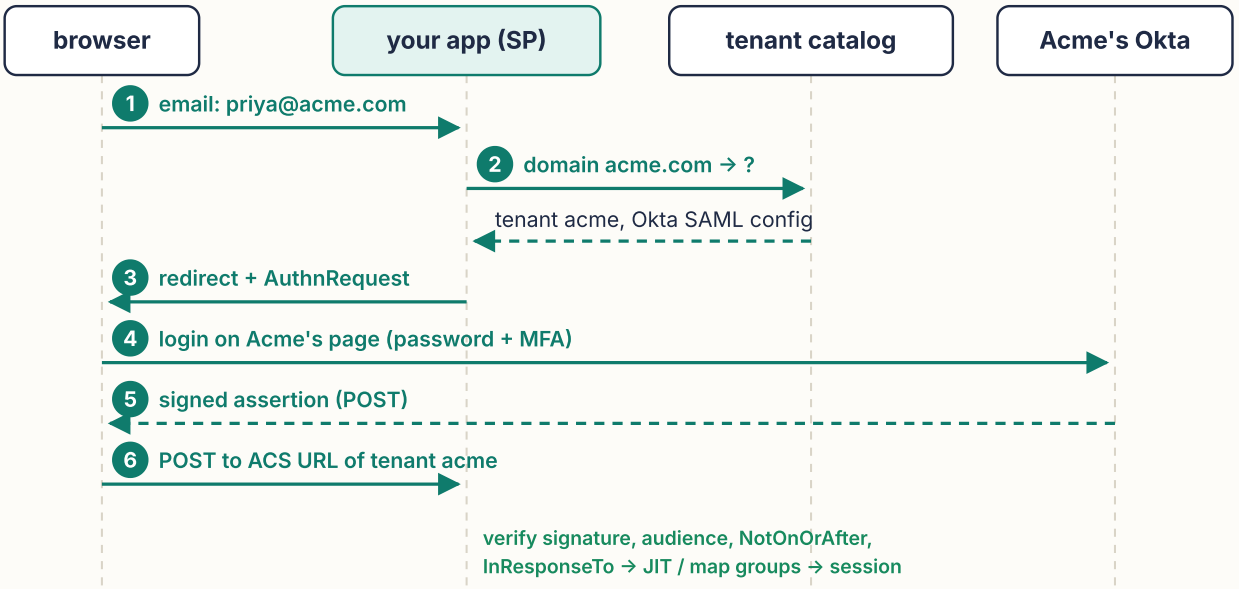


Figure 1. SP-initiated SSO with home realm discovery. The app never sees the password; it trusts the IdP's signed statement.

Two security rules make this safe. **Verify domain ownership** before a tenant can claim a domain (a DNS TXT record), otherwise anyone could register `acme.com` and capture Acme's logins. And identify SSO users by **(IdP, subject ID)**, not by email alone: an email asserted by one tenant's IdP must never log into an account owned by another tenant. Once SSO is enforced for a domain, disable password login for it, keeping one break-glass admin in case the IdP itself is misconfigured.

4 Just-in-time provisioning and its gap

JIT provisioning creates the account on first login from the assertion's attributes: name, email, groups. It's simple and needs no extra integration, but it only sees users when they log in. A leaver never logs in again, so JIT never hears about it: the account lingers, and so do any API keys, long-lived refresh tokens and sessions it created. For many security teams that alone fails the review.

5 SCIM: lifecycle from the directory

SCIM 2.0 (RFC 7643 schema, RFC 7644 protocol) is a standard REST API that **your app exposes** and the customer's IdP calls: `/Users` and `/Groups` with POST, PUT, PATCH and DELETE, authenticated with a per-tenant bearer token. When HR offboards an employee, the IdP sends a deactivation, and your app must do more than flip a flag: revoke sessions and refresh tokens, disable the user's API keys, and record it in the audit trail (lesson 48).

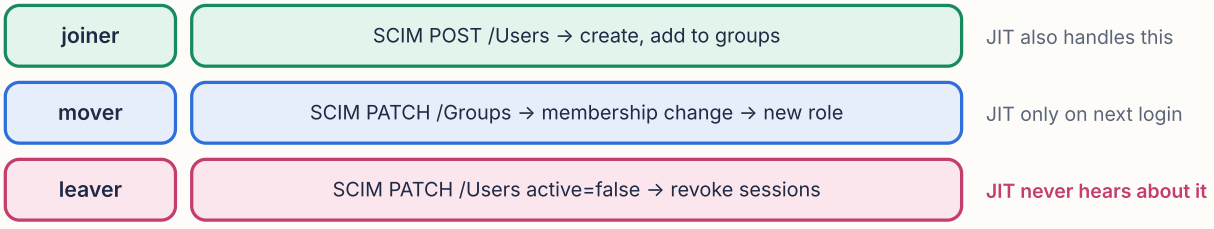


Figure 2. Joiner, mover, leaver. JIT handles only the first well; SCIM handles all three.

```
PATCH /scim/v2/Users/2819c223  HTTP/1.1
Authorization: Bearer <per-tenant SCIM token>
Content-Type: application/scim+json

{ "schemas": ["urn:ietf:params:scim:api:messages:2.0:PatchOp"],
  "Operations": [ { "op": "replace", "value": { "active": false } } ] }
```

Figure 3. A SCIM deactivation as Okta and Entra ID typically send it.

How fast? Okta pushes changes to SCIM apps as they happen; Microsoft Entra ID provisioning runs in cycles, roughly every 40 minutes after the initial sync. If customers need faster cut-off, pair SCIM with short session lifetimes and re-validation of sessions against the user's status.

6 Map directory groups to roles

Permissions should be managed in the customer's directory, not by hand in your app. The tenant admin maps groups to roles (`finance-analysts → viewer`, `finance-admins → admin`); you store the mapping per tenant, keyed by the group's stable ID rather than its display name, and apply it at login and on every SCIM group update. Moving someone between groups in Okta changes their role in your app.

WORKED EXAMPLE: A CUSTOMER'S OKTA TENANT MAPPED TO APP ROLES

Acme's admin adds your app from the Okta catalog, uploads Okta's SAML metadata (entity ID, SSO URL, certificate) in your tenant settings, verifies `acme.com` with a DNS TXT record, and creates a SCIM token. Okta pushes users and groups; the admin maps `sales-managers` to the **manager** role. A new hire, priya@acme.com, is created by SCIM on day one, signs in through Okta and lands with the manager role. When she leaves, Okta deactivates her; your app revokes her sessions and keys within minutes.

COMMON MISTAKES

- Relying on JIT only, so leavers keep access.
- Letting a tenant claim an email domain without verifying it.
- Linking SSO identities to existing accounts by email address.
- Deactivating the user but not revoking sessions, refresh tokens and API keys.

7 Key terms

Identity provider (IdP): the customer's login system, e.g. Okta, Entra ID

Service provider (SP): your app, trusting the IdP

Home realm discovery: picking the IdP from the email domain

JIT provisioning: create the account at first login

SCIM: standard API for user and group lifecycle

Group-role mapping: directory group → app role, per tenant

8 Interview questions

> **Q1. How do you support SSO for many enterprise customers?** BASIC
> Store a separate SAML / OpenID Connect configuration per tenant, use home realm discovery by email domain, provision users with SCIM, and map directory groups to app roles per tenant.

Q2. Why isn't just-in-time provisioning enough? BASIC

It creates users at login but never removes leavers or updates movers who don't log in; SCIM handles deprovisioning and group changes.

Q3. SAML or OIDC? BASIC

Support both if you sell to enterprises: SAML is still common in corporate IT; OIDC is simpler, JSON-based and preferred by modern IdPs.

Q4. A customer's IdP certificate is rotated and SSO breaks. How do you prevent this? SCENARIO

Allow two active certificates per tenant, read the IdP's metadata URL to pick up new certificates, and alert before the current one expires.

Q5. An employee is fired at 10:00. How do you make sure they can't use the app at 10:05? SCENARIO

SCIM deactivation from the IdP, which revokes sessions, refresh tokens and API keys; plus short session lifetimes in case provisioning runs on a cycle.

Q6. Why must tenants verify email domains? TRICKY

Otherwise any tenant could claim another company's domain and route its users' logins to an IdP it controls.

Q7. Why not link an SSO login to an existing account by matching email? TRICKY

The email is asserted by an IdP you don't control; a malicious or misconfigured IdP could assert someone else's email and take over their account.

Next: SD-R-008 · Enterprise Audit Trails backendroadmap.com